

OWASP Top 10:2025

Released by OWASP in late 2025, this is the first major update since 2021. It's built from data on more than 175,000 CVE records and 589 Common Weakness Enumerations, plus community survey input covering over 2.8 million applications. Two categories are entirely new, one is a major expansion, and the focus has shifted explicitly toward **root causes** rather than symptoms.

A01:2025 — Broken Access Control

Still #1. On average 3.73% of applications tested had one or more of the 40 CWEs in this category — the largest CWE count of any category. **SSRF (previously its own A10:2021 category) has been folded into this one.**

Covers: IDOR, privilege escalation, CORS misconfiguration, token manipulation, BOLA/BFLA (broken object/function-level authorization — the most exploited API patterns today), and SSRF.

Prevention: Deny-by-default server-side enforcement; centralize access control logic; test explicitly for BOLA/BFLA; validate and restrict any server-side outbound requests built from user input (to catch the folded-in SSRF cases).

A02:2025 — Security Misconfiguration

Jumped from #5 → #2. 3.00% of applications tested had one or more of the 16 CWEs in this category, driven by how much of an application's behavior is now controlled by configuration rather than code.

Covers: Exposed default accounts, unnecessary services, insecure permissions, missing security headers, misconfigured cloud storage, XXE (CWE-611).

Prevention: Hardened, automated deployment pipelines; continuous configuration scanning (not one-off audits); remove unused features/services; lock down cloud storage permissions by default.

A03:2025 — Software Supply Chain Failures

An expansion of 2021's "Vulnerable and Outdated Components" into something much broader — compromises occurring within or across the entire ecosystem of software dependencies, build systems, and distribution infrastructure. It has the fewest recorded occurrences of any category (only 5 CWEs, hard to test for automatically) but the highest average exploit and impact scores of any category — think SolarWinds-style attacks.

Covers: Compromised build pipelines, malicious/typosquatted packages, unsigned dependency updates, compromised CI/CD infrastructure.

Prevention: SBOM (Software Bill of Materials); signed commits and artifacts; pinned/locked dependency versions; verify package integrity before install;

harden CI/CD access control.

A04:2025 — Cryptographic Failures

Fell from #2 → #4. 3.80% of applications had one or more of the 32 CWEs in this category. Still a major driver of sensitive data exposure and full system compromise.

Covers: Cleartext transmission/storage, weak/outdated algorithms (MD5, SHA1, DES), hardcoded keys, missing certificate validation.

Prevention: TLS 1.2+ everywhere; AES-256 / bcrypt / Argon2; proper key management; don't store sensitive data you don't need.

A05:2025 — Injection

Fell from #3 → #5, but remains one of the most heavily tested categories — the greatest number of CVEs of any category, spanning issues from high-frequency/low-impact XSS to low-frequency/high-impact SQL injection.

Covers: SQL/NoSQL/OS command/LDAP injection, XSS (still lives here, as in 2021).

Prevention: Parameterized queries/prepared statements always; allow-list input validation; output encoding for XSS; avoid string concatenation into interpreters.

A06:2025 — Insecure Design

Fell from #4 → #6. Noticeable industry-wide improvement in threat modeling and secure-design practices since this category was introduced in 2021 is credited for the drop.

Covers: Missing threat modeling, business logic flaws, over-reliance on client-side validation.

Prevention: Threat model at design time (STRIDE, attack trees); reference architectures; test business logic, not just technical controls.

A07:2025 — Authentication Failures

Holds at #7, renamed from "Identification and Authentication Failures" to better reflect its 36 CWEs. Wider adoption of standardized auth frameworks is credited with keeping incidence down.

Covers: Weak/default passwords, no brute-force protection, weak session IDs, missing MFA.

Prevention: MFA by default; no default credentials; check passwords against breached-password lists; secure server-side session management.

A08:2025 — Software or Data Integrity Failures

Holds at #8. Distinct from A03 — this is about failure to maintain trust boundaries and verify integrity of software, code, and data artifacts at a lower level than Software Supply Chain Failures.

Covers: Insecure deserialization, unsigned auto-updates, untrusted plugin/library loading without integrity checks.

Prevention: Digital signatures for code/data; Subresource Integrity (SRI) for third-party scripts; never deserialize untrusted data without validation.

A09:2025 — Security Logging & Alerting Failures

Holds at #9, renamed from "Security Logging and Monitoring Failures" specifically to emphasize the alerting function needed to trigger action on logged events — great logging with no alerting has minimal value for identifying incidents. Chronically underrepresented in test data, kept in the list by community vote.

Covers: Missing audit logs, logs only stored locally, no alerting thresholds, delayed breach detection.

Prevention: Centralized log management (SIEM); real-time alerting on anomalies, not just log collection; incident response plan tied to alerts.

A10:2025 — Mishandling of Exceptional Conditions (*NEW*)

Brand new category with 24 CWEs focused on improper error handling, logical errors, failing open, and other issues stemming from abnormal conditions systems may encounter.

Covers: Fail-open logic (e.g., an auth check that defaults to "allow" on error), verbose stack traces leaking internals, unhandled edge cases in error paths.

Prevention: Fail closed/secure by default; generic error messages to users, detailed ones only to logs; explicitly test error and exception paths, not just happy paths.

2021 → 2025 Mapping

2025 Rank	2025 Category	Came from (2021)
A01	Broken Access Control	A01 (Broken Access Control) + A10 (SSRF, folded in)
A02	Security Misconfiguration	A05 — jumped 5→2
A03	Software Supply Chain Failures	New — expanded from A06 (Vulnerable/Outdated

		Components)
A04	Cryptographic Failures	A02 — fell 2→4
A05	Injection	A03 — fell 3→5 (still includes XSS)
A06	Insecure Design	A04 — fell 4→6
A07	Authentication Failures	A07 (renamed, minor)
A08	Software or Data Integrity Failures	A08 (same slot)
A09	Security Logging & Alerting Failures	A09 (renamed, minor)
A10	Mishandling of Exceptional Conditions	New

Net effect: SSRF no longer stands alone (merged into A01); "Vulnerable Components" is gone as a name, replaced and broadened into Supply Chain Failures; error/exception handling gets its own category for the first time.

OWASP WEBSITE

